

Path to 100% multi-tenant green-tick

The 20 tasks that close the remaining 11% between this codebase and a production-ready shared multi-tenant CRM.

#	Task	What it is (plain English)	Where it lives	Who does it	Time	Cost	How to verify it's done
1	Book external pen test	Hire a security firm to try to break tenant isolation from the outside.	Email Cobalt / HackerOne / NCC Group / Cure53	You	1 hour (today)	\$5-15k	Signed SOW + engagement date on calendar
2	Sign up for Sentry	Get an error-tracking DSN so production exceptions are visible.	sentry.io signup	You	30 min	\$26/mo	SENTRY_DSN set in prod; test exception appears in dashboard with tenant_id tag
3	Review URL audit REVIEW items	Decide classification on 8 routes flagged for engineer review (/media, /v2/admin, OAuth callbacks, etc.).	docs/security/url_audit.md	1 engineer	4-8h	\$0	All 8 REVIEW items have a final classification (auth_required / public / webhook)
4	Add HMAC to webhooks lacking it	Verify Twilio / Facebook / WhatsApp webhooks check signatures before running business logic.	api/security/webhook_verification.py + each webhook view	1 engineer	8-12h	\$0	Posting a webhook without valid HMAC returns 401/403
5	Flip STRICT_AUTH=1 in staging	Enable DRF 'require JWT by default' globally; watch staging for 48h.	Staging env var	1 engineer	2h work + 48h watch	\$0	24 consecutive hours with zero unexpected 401s
6	Flip STRICT_AUTH=1 in production	Same as #5 but in prod, low-traffic window.	Prod env var	1 engineer	4h (incl. monitoring)	\$0	curl <api>; without JWT returns 401 in prod
7	Run all backfill commands	Encrypt existing plaintext tokens + fill new org_id columns.	DB host or app shell	DevOps	4-8h	\$0	SELECT count(*) FROM session_log WHERE access_token NOT LIKE 'ENC1:%'; returns 0 (for each affected table)
8	Provision per-tenant Postgres roles	Run the role + grant creation for every active tenant.	App shell	DevOps	2h + per-tenant verify	\$0	python manage.py provision_tenant_role --all succeeds; cross-tenant probe returns 'permission denied'
9	Deploy PgBouncer	Connection pooling in front of Postgres so worker count > pool size doesn't break tenant isolation.	AWS RDS Proxy / GCP Cloud SQL Proxy / k8s sidecar	DevOps	16h	\$20-200/mo	pg_stat_activity connection count stays bounded under load
10	Run load test	k6 or Locust simulating target traffic; verify no breakage.	Load-generating machine	DevOps	16h	\$0 (or load gen service)	P95 latency + error rate documented at target+2x load
11	Run backup restore drill	Restore yesterday's snapshot to a parallel DB, verify data integrity.	Cloud DB console	DevOps	8h	\$0	docs/runbooks/restore_drill.md filled in with measured RTO/RPO
12	Wait 2 weeks for clean RLS soak	Phase 4 part 2 in prod with zero permission denied or policy violation errors.	Production logs	Engineer (watch only)	14 days calendar	\$0	Grep prod logs for last 14 days -> zero RLS-policy hits
13	Flip FORCE ROW LEVEL SECURITY	Final tightening - even main role subject to RLS.	New migration 0016_force_rls_shared_tables.py	1 engineer	4-8h + ops audit	\$0	SELECT relname, reforcerowsecurity FROM pg_class WHERE relname IN (...) shows t for all 5
14	External pen test executes	Pen test firm runs the engagement they were booked in #1.	Their tooling, your staging	Pen test firm	2-3 weeks	(paid in #1)	Final report delivered; zero open High/Critical findings
15	Wire property tests into CI	Hypothesis tests run automatically on every PR touching security paths.	.github/workflows/security-tests.yml	1 engineer	4-8h	\$0 (GH free tier)	PR check appears on next security-touching PR
16	DPA + ToS + Privacy Policy	Legal docs covering data processing, customer obligations.	Legal counsel	Counsel	1-2 weeks	\$2-5k legal fee	Documents signed off; published on website
17	Cyber liability insurance	Coverage for breach costs (notification, forensics, customer remediation).	Insurance broker	You	1-2 weeks	\$1-5k/yr	Policy bound; certificate received
18	Status page	Public dashboard for uptime + incident communication.	statuspage.io / Better Stack / self-host	DevOps	4h	\$0-29/mo	status.yourdomain.com loads with green-all-good
19	On-call rotation + paging	Someone gets paged when alerts fire.	PagerDuty / Opsgenie / Better Stack	DevOps	4h	\$25-50/seat/mo	Test page reaches on-call's phone
20	Tabletop exercise	Walk through the cross-tenant leak runbook in a meeting; find gaps.	Conference room / Zoom	Whole team	2h	\$0	docs/runbooks/incident_response_cross_tenant_leak.md updated with gaps found

Sequence by week

Week	Items	Bottleneck
0 (today)	#1, #2	Calendar — pen test waitlist
1	#3, #4, #7, #8	Code review on URL audit
1-2	#5 (staging soak), #9, #11	48h soak time
2	#6, #10, #15, #16, #17, #19	Production deploy window
2-4	#12 (clean soak)	Calendar — 2 weeks of monitoring
3-5	#14 (pen test)	Pen test firm's calendar
5	#13, #18, #20	Prerequisites met
6	Green tick → open signups	None

Cost summary

Type	Item	Amount
Upfront one-time	Pen test (#1, #14)	\$5-15k
Upfront one-time	Legal review (#16)	\$2-5k
Recurring monthly	Sentry (#2)	\$26
Recurring monthly	PgBouncer / RDS Proxy (#9)	\$20-200
Recurring monthly	Status page (#18)	\$0-29
Recurring monthly	Paging tool (#19)	\$25-50
Recurring yearly	Cyber insurance (#17)	\$1-5k
Upfront total		\$7-20k
Monthly total		\$70-300
Annual recurring total		\$1.8-9k

Per-role time investment

Role	Total hours	What they do
You	~3 hours	Book pen test, sign up Sentry, sign legal docs, bind insurance
1 engineer	~50 hours (over 3 weeks)	A4 rollout (#3-6), property tests CI (#15), FORCE RLS (#13)
1 DevOps	~60 hours (over 3 weeks)	PgBouncer (#9), backfills (#7), provisioning (#8), load test (#10), restore drill (#11), status page (#18), paging (#19)
Legal counsel	~10 hours (over 2 weeks)	DPA + ToS + Privacy Policy (#16)
Pen test firm	2-3 weeks engagement	External pen test (#14)
Whole team	2 hours	Tabletop exercise (#20)